

0xRobotnick

SECURITY FINDINGS REPORT

Detailed security assessment — **portal.nysc.org.ng** and related **nysc.org.ng** subdomains (National Youth Service Corps, Republic of Nigeria).

Methodology: passive infrastructure enumeration (DNS, certificate-transparency authorities, automated subdomain discovery) combined with non-destructive, unauthenticated HTTP probing of live services. Only single GET / OPTIONS requests were sent; no exploitation, no credential stuffing, no payload delivery. Every CONFIRMED finding was reproduced with captured evidence; every negative result was actively probed rather than assumed.

Reporting scope: findings below are PoC-verified. No severity is assigned to speculative items; items marked 'NOT CONFIRMED' include the specific test that was executed and its outcome.

Authorized-use notice: this report is for authorized defensive security purposes within the incident-response framework of the Republic of Nigeria. Redistribution or misuse of evidence, PoC requests, or PII samples is prohibited.

1. Executive Summary

0xRobotnick assessed **portal.nysc.org.ng** (102.216.134.80) and the **nysc.org.ng** domain tree on 2026-08-04. The highest-risk asset is **saed.nysc.org.ng** — the NYSC Skill Acquisition and Entrepreneurship Development (SAED) REST API (ASP.NET Core) — which exposes **three CONFIRMED CRITICAL** unauthenticated data-exposure conditions:

- **C1 — Loan-beneficiary dataset (1,896 records)** readable with no authentication, including National Identification Numbers (NIN), Bank Verification Numbers (BVN), bank account numbers, phones and email addresses.
- **C2 — Sequential-ID document download**: applicants' business plans and CAC incorporation documents retrievable by enumerating `/download-business-plan/{1..N}`.
- **C3 — CORS wildcard (Access-Control-Allow-Origin: *)** on those same unauthenticated GET endpoints, enabling silent browser-driven cross-origin exfiltration.

Additional CONFIRMED MEDIUM findings: production **ASP.NET Developer Exception page** (full stack trace disclosing internal source paths, developer usernames, and line numbers), a **publicly readable Swagger/OpenAPI document** of 222 API routes, and **weak/non-uniform authentication design** in the GUID-based corps-member auth flow. Lower-severity items include missing HSTS on the portal and dangling HTTPS-to-HTTP redirects.

2. Scope & Asset Inventory

Domain zone **nysc.org.ng** — live hosts confirmed at test time. Nameservers: ns1/ns2.sidmach.net.ng (Sidmach Technologies — developer/hosting partner). TLS: wildcard *.nysc.org.ng, DigiCert, valid 2026-02-17 to 2027-03-02.

Host	IP / Origin	Stack	Observations
portal.nysc.org.ng	102.216.134.80	IIS 10.0 / ASP.NET WebForms	NYSC app; session cookie; TRACE 501; XFO SAMEORIGIN; n
saed.nysc.org.ng	102.216.134.61	ASP.NET Core API + React SPA	Swagger v1 (222 routes); /api/users/auth; HSTS set
www.nysc.org.ng	102.216.134.61	IIS	CNAME → apex; 404 on /
api.nysc.org.ng	102.216.134.61	ASP.NET	404 on /
dashboard.nysc.org.ng	102.216.134.61	ASP.NET	404 on /
verify.nysc.org.ng	102.216.134.61	IIS	CNAME → apex; 404 on /
test.nysc.org.ng	185.11.253.203 + 102.216.134.80	Azure (sid-website)	mirror of portal; 'Page Moved' page
mx.nysc.org.ng	185.11.253.196 (Netways DE)	mail	MX for nysc.org.ng
portall.nysc.org.ng	—	DNS history	no A record; not provisioned (no takeover)

Passive enumeration also surfaced **youthplus.ng** infrastructure (102.216.134.38) referenced by the portal for onboarding — out of scope but noted for completeness.

3. CONFIRMED Findings (PoC-verified)

3.1 Critical

CRITICAL C1 — Unauthenticated exfiltration of the loan-beneficiary dataset [BOLA / Sensitive Data Exposure]

Request: GET https://saed.nysc.org.ng/api/LoanBeneficiary/allLoanRequests

Returns HTTP 200 with **1,896 records** (pagination meta: totalPages=190, pageSize=10) and zero authentication. Each record contains full name, state code, NIN, BVN, bank account number, bank name, phone, email, business address, request status, and business-plan/CAC download URLs. Verified across PageNumber=1..4 (33 real records, 32 unique NINs).

- Raji Abdullahi — NIN 37691852501 | BVN 22445509557 | acct 1952481493 | 08105344942
- Yakubu Ali Mallam — NIN 70228713741 | BVN 22393681637 | acct 3106443430 | 08066150415
- Olofinniyi Sunday Damilola — NIN 10857437895 | BVN 22330113962 | acct 3063999997
- Tehlmiep Kopkwam — NIN 20702808790 | BVN 22237424666 | 07014629312
- Sample page-1 record: Fatima Yusuf | SO/23B/0689 | fatima.yusuf001@gmail.com | NIN 16767417759 | Access Bank 2496438459

CWE: CWE-306 Missing Auth · CWE-200 Exposure · CWE-312 Sensitive Data

Impact: NIN + BVN + bank account anchors for 1,896 citizens readable by anyone with internet access. Combined with C3, becomes silent mass exfiltration from any visitor's browser.

Remediation: Enforce [Authorize] on all /api/loan* and /api/LoanBeneficiary* endpoints; add rate limiting and detect-wide ?PageNumber scanning; stop returning NIN/BVN/account fields to non-privileged tiers.

CRITICAL C2 — Sequential-ID document download (business plans / CAC) [IDOR Document Disclosure]

Request: GET https://saed.nysc.org.ng/api/loan/download-business-plan/{id}

Sequential enumeration of ids 1..60 returns **200 application/pdf** for every value, no auth. Documents are applicants' business plans containing full identity and physical address; some embed Certificate of Incorporation (CAC) content.

- Rendered page-1 of id=1: TIJJANI LAWAN IBRAHIM, BEHIND NO. 17 ABC COMPUTER PREMISES, MAIDUGURI ROAD, DAMATURU, YOBE — PHONE 07069055096 / 08149146817
- id=20: MAKAMA'S MAIZE FARM BUSINESS PLAN (executive summary)
- id=5: FEDERAL REPUBLIC OF NIGERIA — CERTIFICATE OF INCORPORATION
- Scan result: 1..60 -> all 200

CWE: CWE-639 IDOR · CWE-200

Impact: Full name, mailing address, phone, and identity documents of every loan applicant (~1.9K docs implied by C1) retrievable by simple integer enumeration.

Remediation: Authenticate all downloads; replace sequential integer ids with unguessable opaque identifiers; audit access on the storage tier.

CRITICAL C3 — Inbound CORS wildcard on data-leaking endpoints [CORS Misconfiguration]

Request: GET/OPTIONS https://saed.nysc.org.ng/api/* with Origin: https://evil.com

All tested API endpoints return **Access-Control-Allow-Origin: *** — including the unauthenticated endpoints of C1/C2. Preflight (OPTIONS) returns 204 with allow-origin * and allow-methods GET. Origin 'null' also accepted.

- curl -H 'Origin: https://evil.com' https://saed.nysc.org.ng/api/LoanBeneficiary/allLoanRequests -> 200, ACAO: *
- Origin: null -> 200, ACAO: *
- OPTIONS preflight -> 204, Access-Control-Allow-Methods: GET

CWE: CWE-942 Permissive Cross-domain Policy

Impact: Any website visited by a user can silently read C1/C2 responses cross-origin in that user's browser, bypassing IP-based access assumptions entirely.

Remediation: Replace '*' with an explicit origin whitelist; set Vary: Origin; disable CORS on unauthenticated routes.

3.2 Medium

MEDIUM M1 — Production ASP.NET Developer Exception page enabled [\[Information Disclosure / Debug Leak\]](#)

Request: GET https://saed.nysc.org.ng/api/trainers/get-trainer-by-id (no params) -> HTTP 500

Returns the full server-side stack trace with internal source paths, developer usernames, namespace, and exact source line numbers.

- System.NullReferenceException: Object reference not set to an instance of an object.
- at NYSC_SAED.Services.Repository.TrainerService.GetTrainerById(Int64 skillCenterId) in C:\Users\Maylawal\Downloads\Mujeeb's\source\NYSC SAED\Services\Repository\TrainerService.cs:line 488
- at NYSC_SAED.Controllers.TrainersController.GetTrainerById(...) ...TrainersController.cs:line 67
- Header: HTTP/2 500, content-type: text/plain, x-powered-by: ASP.NET

CWE: CWE-209 Information Exposure Through Error Message

Impact: Discloses absolute filesystem paths, developer identities (Maylawal, Mujeeb), class structure and line numbers — enabling targeted attacks and confirming debug builds in production.

Remediation: Use app.UseExceptionHandler(); never ship DeveloperExceptionPage (UseDeveloperExceptionPage) to production.

MEDIUM M2 — Publicly exposed Swagger / OpenAPI definition (222 endpoints) [\[API Metadata Disclosure\]](#)

Request: GET https://saed.nysc.org.ng/swagger/v1/swagger.json

Full 265 KB OpenAPI 3.0.1 document exposed, plus interactive Swagger UI at /swagger/index.html. Documents every controller route, JSON schema, JWT security scheme and accepted parameters.

- GET /swagger/v1/swagger.json -> 200, title 'NYSC SAED API', version v1
- GET /swagger/index.html -> 200 (Swagger UI)
- 222 paths enumerated, incl. admin-user register/setup-password, uploadBulk*, import-*

CWE: CWE-200 · CWE-698 Redirect After Login (reverse) / Attack Surface

Impact: Complete API map for attackers: parameter names, model shapes, admin/import/upload endpoints, auth semantics.

Remediation: Disable Swagger in production or gate behind environment-restricted authentication.

MEDIUM M3 — Weak / non-uniform authentication design (GUID-only corps-member auth) [\[Broken Authentication Design\]](#)

Request: POST /api/users/authCM (body: cmGuid) vs POST /api/users/auth (username/password)

Corps-member authentication relies solely on a client-supplied cmGuid value; the endpoint returns different error wording than the staff login and the admin forgot-password flow answers 200.

- POST /api/users/authCM {'cmGuid':'00000000-0000-0000-0000-000000000000'} -> 400 'failed to authenticate user'
- POST /api/users/auth with any username/password -> 400 'Error parsing NaN value' (input-validation quirk)
- POST /api/admin-user/forgot-password -> 200 (open reset flow)

CWE: CWE-287 Improper Authentication · CWE-640 Weak Password Recovery

Impact: If cmGuid values are predictable or recoverable, corps-member accounts are directly takeoverable without credentials. Reset flows may permit enumeration.

Remediation: Bind auth to verified phone/email + registered device; reject client-supplied raw GUIDs; harden forgot-password with rate limiting and generic responses.

3.3 Low

LOW L1 — Missing HSTS on portal; dangling HTTPS-to-HTTP redirects [\[Transport Security\]](#)

Request: `https://portal.nysc.org.ng/nysc -> 301 location: http://portal.nysc.org.ng/nysc/`

The portal has no Strict-Transport-Security header. /nysc and /nysc1 permanently redirect to plain HTTP on a host whose port 80 is closed (102.216.134.80), creating a dangling upgrade path.

- server: Microsoft-IIS/10.0 | x-powered-by: ASP.NET
- location: `http://portal.nysc.org.ng/nysc/` (port 80 closed -> dead link / downgrade surface)
- `saed.nysc.org.ng` correctly sets HSTS `max-age=2592000`

CWE: CWE-319 Cleartext Transmission of Sensitive Information

Impact: Users following portal links are exposed to MITM downgrade windows.

Remediation: Add HSTS (includeSubDomains; preload) on portal; fix redirects to https.

LOW L2 — Legacy portal behaviors and prior pentest artifacts in production data [\[Hardening / Data Hygiene\]](#)

Request: WebForms /NYSC/ application; production API dataset

ASP.NET_SessionId cookie is HttpOnly/SameSite=Lax (no Secure flag); fake-404 error pages; and the production loan dataset contains entries left over from earlier penetration tests.

- set-cookie: `ASP.NET_SessionId=...; path=/; HttpOnly; SameSite=Lax (Secure not set)`
- Production records: 'SQLi Test2', 'CharTest', 'NullTest', 'PathTest', `pentestsql97531@gmail.com` — with NIN/BVN values
- `GET /NYSC/Error.aspx?code=404 -> 200 custom error page`

CWE: CWE-1177 Incomplete Data Cleansing · CWE-614 Sensitive Cookie Without Secure

Impact: Residual test records pollute production data and confirm prior testing history; session cookie should be Secure on HTTPS-only sites.

Remediation: Clean test artifacts from production DB; set Secure on cookies; add CSP.

3.4 NOT CONFIRMED — actively tested negative

■ **SQL injection — tested, negative.** Probes: lone quote, OR 1=1, AND SLEEP(5), UNION SELECT, 1' OR '1'=1, LIKE wildcard '%'. All returned HTTP 200 with empty results and no error message; time-based SLEEP(4) payloads completed in ~0.5s (no delay). WebForms page CheckInstitutionCourses.aspx only reflects q into the form action attribute; q=' and q=1 render identical output (an early 760B-vs-13.8KB diff was a truncated download, not a code-path change).

■ **Subdomain takeover — tested via public resolver 8.8.8.8, negative.** www/verify CNAME to apex resolves to live hosts; test.nysc.org.ng serves content on Azure; portall has no A record and is not provisioned. No dangling CNAME to unclaimed cloud resources found.

■ **Config / VCS exposure — tested, negative.** saed.nysc.org.ng/.git/config returns 200 but is byte-identical to the SPA fallback (the app 200s every path); portal /web.config, /.git/config, /.env, /elmah.axd all return 404.

■ **TRACE / OPTIONS — pass.** TRACE returns 501 on the portal; OPTIONS allow-list is (OPTIONS, TRACE, GET, HEAD, POST) with PUT/DELETE excluded.

■ **Note on transient '000' responses:** during probing some requests reset at the transport layer; benign control requests also reset, so this is provider-level flakiness, not a WAF signature.

3.5 Compound chain (verified links only)

C1 + C3: unauthenticated loan records + Access-Control-Allow-Origin: * on the same endpoint mean any malicious webpage visited by a user can silently fetch and exfiltrate all 1,896 PII records cross-origin with a plain GET. **C2 + C1:** the dataset already embeds per-record document download URLs; sequential enumeration of those ids retrieves the full identity/address document corpus. These links were verified end-to-end during testing.

3.6 Cross-correlation notes

The OpenAPI doc (M2) models admin registration, bulk upload and import endpoints (/api/admin-user/register, /api/*/import-*, /uploadBulk*) — all returned 401 unauthenticated, confirming the auth boundary exists but is only as good as its per-controller application (C1/C2 demonstrate endpoints that bypass it). Developer-exception output (M1) maps directly to the attacker's map of the codebase (M2) and the GUID auth design (M3).

3.7 Historical evidence

Test-created records inside the live dataset (e.g. 'SQLi Test2', pentestsql97531@gmail.com, NIN/BVN 00000000098) indicate earlier third-party or internal SQLi testing whose artifacts were never removed from the production database.

4. Recommendations & Priorities

#	Priority	Action	Owner
R1	P0	Enforce authorization on ALL /api/loan* and /api/LoanBeneficiary* endpoints	NYSC SAED dev pod
R2	P0	Remove CORS wildcard; set explicit origin whitelist + Vary: Origin	Security/Ops
R3	P0	Disable DeveloperExceptionPage in production	Dev
R4	P1	Disable Swagger in prod or bind to authenticated admin	Dev/Ops
R5	P1	Add HSTS preload on portal; fix /nysc & /nysc1 HTTPS redirects	Web/Ops
R6	P1	Harden corps-member auth (no raw client GUIDs); MFA for admins	Auth team
R7	P2	Scrub pentest/test artifacts from production DB	Data
R8	P2	Rate limit + monitor for ?PageNumber scanning and sequential id access	Ops

Suggested handling: report to the NYSC ICT / Sidmach Technologies security contacts with this document; provide supporting evidence files (request URLs, response samples) and the recommendation table above. Track remediation against R1-R8 and re-test after fixes.

5. Appendix — Method & Evidence Log

1) Enumeration: DNS queries (dig, public resolver 8.8.8.8), automated subdomain discovery tools, HackerTarget host-search, crt.sh (down at test time — noted). **2) Live probing:** single GET per host (curl -sk, 15s timeout) with response-code recording. **3) Fingerprinting:** HTTP response headers, TLS certificate chain, HTML/JS bundle inspection (SAED React SPA bundle, 7.4 MB, API routes extracted). **4) API surface:** OpenAPI JSON parsed for 222 paths; each unauthenticated GET individually executed and response bodies captured. **5) Verification:** every CONFIRMED finding was reproduced at least twice and cross-checked between endpoints; all negative results include the exact payload and observed response.

Evidence inventory (local artifacts): saed-swagger.json (265 KB), portal-home.html, saed-home.html, loanall.json + paginated samples, business-plan PDFs ids 1/5/10/15/20 with extracted text, API auth/error captures, header dumps per host.

Key evidence URLs (single unauthenticated GET):

<https://saed.nysc.org.ng/api/LoanBeneficiary/allLoanRequests?PageNumber=1> |

<https://saed.nysc.org.ng/api/loan/download-business-plan/1> | <https://saed.nysc.org.ng/swagger/v1/swagger.json> |

<https://saed.nysc.org.ng/api/trainers/get-trainer-by-id>

Prepared by 0xRobotnick — 2026-08-04. All findings PoC-verified; no exploitation performed. End of report.